

Can SOC Operators Explain their Decisions while Triaging Alarms? A Real-World Study

Jessica Moosmann¹, Irdin Pekaric¹, and Giovanni Apruzzese²¹

¹ University of Liechtenstein, Vaduz, Liechtenstein

² Reykjavik University, Reykjavik, Iceland

Abstract. Security Operations Centers (SOCs) are pivotal in modern enterprises. Tasked to monitor complex network environments constantly under attack, SOC can be active 24/7 and can include hundreds of operators supported by state-of-the-art technologies. Abundant research has studied the internal processes of SOC, highlighting their pros and cons, as well as the challenges faced by SOC analysts—such as dealing with the overwhelming number of false alarms triggered by automated security mechanisms. In this context, we wonder: given that “someone” must triage the alarms, and that such triaging must be grounded on established knowledge or evidence-based reasoning, *can SOC employees justify why a certain decision was taken while triaging alarms?* Answering such a research question (RQ) can better guide future efforts.

We hence tackle this RQs. First, via a systematic literature review across 257 research documents, we provide evidence that such RQ received limited attention so far. Then, we partner-up with a real-world SOC and carry out a field study (n=12) with SOC employees. We show them real alarms raised in their SOC, and inquire whether such alarms are indicative of true security problems or not. Then, we ask to explain their decision. We found that while most analysts were able to separate “true from false” alarms (the decision was correct in 83% of the cases), a correct justification was hardly provided (only 39% of the provided explanations reflected the actual root cause). Ultimately, our results highlight the need for decision-support systems that help SOC analysts not only make the right call—but also understand and articulate *why* it is right.

1 Introduction

Organizations worldwide are constantly targeted by cyberattacks [62,10,17]. To address this problem at scale, Security Operation Centers (SOC) are a fundamental asset to businesses of any size [14,47]. Mostly operating 24/7 and typically having 2–10 staff members [47], SOC protect the network perimeter of various companies by preventing incoming threats, detecting intrusions, as well as implementing and enacting recovery plans [47]. To this purpose, SOC leverage state-of-the-art tools, such as system information and event management (SIEM) platforms, which are kept up-to-date with the most recent security feeds [47].

The criticality of SOC in the current information-technology (IT) landscape is established [47]. As such, lots of scientific research focused on SOC, proposing

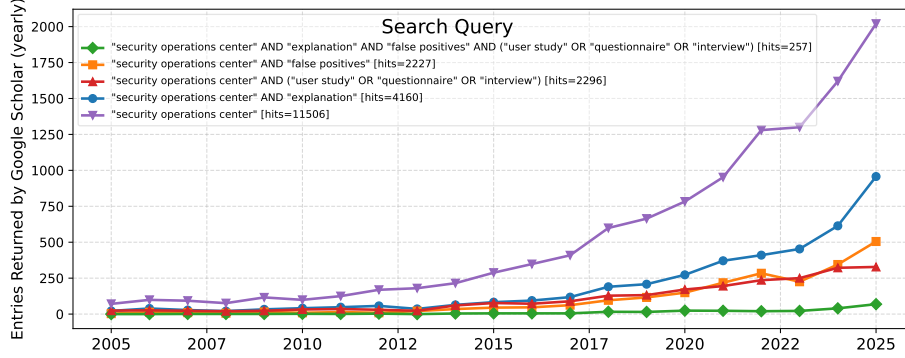


Fig. 1: **Research interest in Security Operations Centers (SOC).** Results returned by issuing specific queries in Google Scholar. For “security operation centers”, we considered variants (e.g., the complete term was “(‘security operation center’ OR ‘security operations center’ OR ‘security operation centre’ OR ‘security operations centre’)”; for “false positives” we considered: “(‘false alarm’ OR ‘false positive’ OR ‘false alert’)”; for “user study”, we considered “(‘user survey’ OR ‘user study’)”; for “explanation”, we consider “(‘explainability’ OR ‘explainable’ OR ‘explain’ OR ‘explanation’)”.

methods to improve their workflows [60], enhancing deployed systems [59,50], analysing pain points [5], or exposing their weaknesses [44]. To portray the historical “research interest” towards SOC, we show in Fig. 1 the number of results returned (yearly) by Google Scholar by issuing various SOC-related queries in the last 20 years. Accordingly, over 11k scientific documents have tackled the domain of SOC. Recurrent themes involve, e.g., the problem of *false positives*, triggered by the overwhelming amounts of data processed by various devices which must be analysed and upon which high-stakes decisions must be taken [36]. Such processes lead to the well-known *alert fatigue* and decrease the efficiency of SOC employees [55]. Nevertheless, SOC analysts are also expected to *explain* why a certain decision was taken—especially when they need to justify, to their customers, why an incorrect decision was made [6].

In this context, and also given that SOC-related infrastructures are recognized also by legal bodies, industry standards, and institutional boards [3,2,26], we took a step back, and one research question (RQ1) surfaced. *Can SOC analysts explain their decisions while triaging alarms?* Indeed, modern environments generate alarms, not all of them being indicative of security-noteworthy events [35]; for instance, Yang et al. [63] claim that most alarms are due to so-called *benign triggers*, deriving from apparently malicious behaviors but stemming from benign causes (e.g., a scheduled vulnerability scan launched by a security appliance). We hypothesize that some of these alarms can be trivial to resolve, especially if appropriate context is given. But what if the alarms are more challenging to triage? In these cases, and given that a decision must be made (e.g., either to invest resources in troubleshooting the problem—potentially leading to time waste; or ignore the problem—and potentially causing a security breach), can the operators provide a plausible explanation for their choices?

We argue that RQ1 has plenty of practical implications. For instance, if the answer is a clear “yes”, then it means that existing infrastructures (encompassing both IT systems as well as documentation and management) provide good support to SOC analysts. Conversely, if the answer is “not so much”, then it would

indicate that there is a need for better decision-support systems [30]. Regardless, tackling RQ1 also simultaneously enables one to address another research question (RQ2): *Are certain alarms harder to triage than others?* Indeed, investigating RQ1 requires to show various alarms to SOC operators and record (i) the decision and (ii) the explanation. Although the 2019 study by Kokulu et al. [31] argues that false positives do not have a significant impact on the operation of the considered SOC, we believe that exploring RQ1 and RQ2 is instrumental to guide future research: if certain “false alerts” are systematically easier to triage, then specific rules can be defined so as to avoid burdening analysts—whereas ad-hoc tools would be needed to handle more complex cases.

Contributions. In this work, we conduct a case study in a real-world SOC to investigate RQ1 and RQ2. Let us summarize our major contributions:

- As a first step, we examine if RQ1 had been previously explored. Through a systematic literature review across 257 related documents, we found only one peer-reviewed work [29] that can be said to be truly related to RQ1. However, the research in [29] did not specifically focus on RQ1, since the respective user study (n=4) was meant to validate the output of a research prototype.
- Then, to shed more light, we find an agreement with a SOC in Europe and carry out a field exercise with 12 full-time analysts (§3). Our study encompasses over 30k events distributed across six cases of different triaging difficulty. For each case, participants must provide a decision (true or false alarm) and justify their choice via open-text answers. The decision was correct in 83% of the answers, but 61% of the explanations were incorrect or imprecise (§4).
- Qualitative analyses based on a pre- and post-study questionnaire revealed that expertise or self-confidence do not reflect a participant’s explanation accuracy. Moreover, some cases were perceived as systematically harder to triage, with participants commenting that there was “missing information” (even though they were provided with all the necessary tooling).

We do not seek to generalize our results to all SOCs, but our findings can be instrumental for future work (§5). We provide additional details in our repo [1].

2 Background and Motivation

We outline fundamental concepts of SOCs (§2.1), and then discuss our literature review (§2.2), which underpins the research gap tackled by our work (§2.3).

2.1 Security Operations Centers (SOC)

Security Operations Centers have been extensively covered in prior research (refer to Fig. 1). Recent summaries and reviews, such as [55,46,30], provide a comprehensive overview of the current state of SOCs. In what follows, we pinpoint the elements that are most necessary to appreciate our contributions.

A SOC is a central unit within a company whose main task is to (continuously) monitor their Information and Communication Technology environment [67]. It is common [67,5] to distinguish three key components that, if properly orchestrated, lead to an effective SOC: *people*, *processes*, and *technologies*.

We provide in Fig. 2 a sketched architecture of a typical SOC (supported also by the analysts of our considered SOC). SOC’s teams typically encompass 2–10 *people* [47]: while (security) analysts are those responsible for handling security incidents, other specialized personnel (e.g., engineers) are also crucial to ensure a smooth workflow [31,52]. *Processes* serve to establish the necessary boundaries that define how *people* interact with *technologies*. For instance, instructions as to how to deal with alarms, what activities are or not allowed by certain hosts, or who to contact in case of a breach—all such information can be found in process-related documents (typically known as *playbooks* [52]). *Technologies* encompass all the technical infrastructure that embeds the core functionality of the SOC. The most popular tools include SIEMs [63], which typically are developed by well-known security vendors (e.g., Splunk [51]); however, a SOC can also rely on ad-hoc and custom software. Such software is designed to receive data inputs from a variety of *Log Sources*. Traditionally, such log sources encompass IT devices, such as firewalls or routers; however, in select SOC’s, these log sources can also include “Operational Technology” (OT) devices, such as PLC or components typically deployed in industrial control systems [15,33].

Numerous long-standing problems affect SOC environments. For instance, false alarms—for which it is even hard to even provide an universally-recognised definition (e.g., the “benign triggers” envisioned by [63] are not considered false positives according to [5]; and regardless, Kokulu et al. [31] argue that, after all, false positives do not have a significant impact on SOC’s). Another closely related issue is that of *explainability* [36,6]. SOC environments are becoming increasingly more complex, and analysts must make more decisions which, in turn, should account for more data. As such, analysts are on the lookout for tools that “explain” the root cause of a certain event (or, alternatively, “why an alarm was raised”). Such additional input can hence be used to make an informed decision in the presence of overwhelming amounts of datapoints [5,38]. Otherwise, as previous studies indicated [11,40,43], analysts may rely on intuition or gut feelings, which can cloud their judgment and lead to irrational decisions.

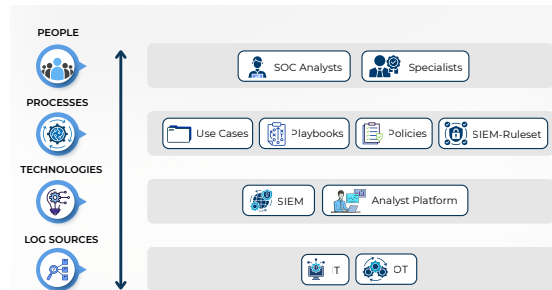


Fig. 2: Typical SOC architecture (IT-Information Technology, OT-Operational Technology).

2.2 Systematic Literature Review

We began our study with a broad research question (RQ0): *has prior work carried out user studies in which SOC practitioners were asked to triage alarms and explain their decisions?* To answer RQ0, we carry out a systematic literature

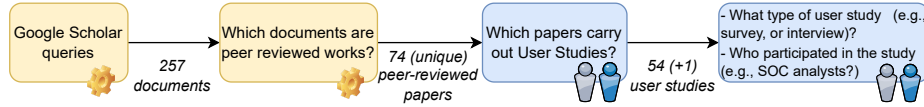


Fig. 3: Overview of the methodology of our SLR. The qualitative analysis was done by two authors.

review (SLR), following established PRISMA guidelines [37]. A depiction of our methodology is in Fig. 3 (more details are reported in the Appendix A.1).³

Paper Collection. We collected works via Google Scholar. We devised a search query revolving around four keyword groups: “SOC”, “explainability”, “user study”, and “false positives”. Intuitively, a paper that addressed RQ0 (implicitly or explicitly) should mention these terms at least once (refer to the caption of Fig. 1 for the exact queries). We filter the results between 2005–2025 (the earliest document appeared in 2007 [23]). Overall, we obtain 257 papers.

Screening. Next, we remove results not relevant for RQ0. We remove all non-peer-reviewed works (e.g., preprints [49] or theses/books [23,13]). This way, we obtained 74 papers. Then, we manually checked the content of these papers, seeking to identify papers that *carried out user studies*. 19 papers only mentioned terms related to user studies as generic recommendations (e.g., [56]) or to refer to prior work (e.g., [55]). However, while inspecting such works, we found one paper that is very relevant for RQ0, i.e., [18] which we added to our SLR.⁴

Analysis. We manually analysed our set of 55 papers carrying out user studies. We sought to answer two questions: (i) “what type of user study is carried out?” (ii) “are the participants SOC practitioners?”. For the first question, we found that 34 papers carried out interviews, whereas 9 used asynchronous surveys/questionnaire; four papers carried out a mixed-method study [46,52,29,58], and seven carried out a field-study exercise [65,66,53,44,27,34,7]. For the second question, only 14 papers made it explicit that the participants were *exclusively* SOC professionals: other works consider generic employees [9], or pooled SOC analysts with non-SOC members (e.g., [39]), or a broad “security specialists/professionals/researchers” (e.g., [24,36]). Nonetheless, some papers clearly did not cover SOC environments (e.g., [45]): among our 55 papers, we could only map 39 to SOC-specific contexts (e.g., triaging alarms while accounting for real-world constraints). For transparency, we report the full results of our SLR in [1].

2.3 Related Work and Research Gap

To fully answer RQ0, we assessed the papers found through our SLR once more, asking ourselves: “is the paper about explaining the decisions made by analysts?”

³ We carried out a preliminary investigation in Dec. 2024; we repeated this process in Dec. 2025 to ensure that, at submission time, our answer is still valid; and further validated our findings by double-checking [21] our results a third time in Feb. 2026.

⁴ This work was not captured by our query because [18] it mentions “explainable alerts” and not “false alerts”; all works relevant to RQ0 should mention “false alerts/alerts/positives”, but to avoid missing these cases we inspected also the references. Specifically, we found [18] while reviewing the recent survey by Tariq et al. [55].

In what follows, we briefly discuss our results, highlighting the works that are closest to our purpose—and which also support our overall research.

The authors of [34] carry out a proof-of-concept evaluation of a framework meant to study the explainability of AI-driven methods: this is done via a survey across 7 participants who should serve as a proxy of “potential cybersecurity analysts”. However, aside from the unclear background of participants, the assessment is based on research prototypes, and does not reflect an operational SOC environment. The seminal work by [5], followed by other recent works from top-tier venues [46,36], contributed with the results of 15–21 interviews with SOC (or security-focused) professionals. However, while these works serve to highlight common operational pain-points, the findings are based on the perceptions of the interviewees—in other words, there is no actual assessment of the practitioners’ ability to explain their decisions (or triage false alarms). The research in [18] involves a user study, done with 10 SOC analysts, focused on assessing the quality of *eXplainable AI* techniques in a SOC context. Despite being conceptually similar to our goal (i.e., assessing explanations), there is a fundamental difference because the study in [18] focuses on assessing software-generated explanations, whereas we focus on human-generated explanations.

Three very close works are [32], and [65,66]. The former [32] inquires 15 analysts within the same SOC about the perception of the output of the solution proposed in the corresponding paper, asking questions such as “do you think you understood what this IOC means?” which could be answered with a 5-point Likert scale: such an instrument, again, mostly reflects the perception of the participant. The authors of [65,66] conduct a full-fledged simulation (across “30 professional analysts from Army Research Lab”) sought to measure the participants ability to triage alarms. However, the data used for this experiment was not that of the SOC wherein the participants worked, but was generated through a simulation which occurred years before the study took place; moreover, there is no assessment of the participants’ ability to explain their decisions.

The work most aligned with RQ0 is the paper by Kersten et al. [29]. They carry out a study with four SOC practitioners asking which alerts are “interesting” (which can be a way to gauge if the practitioner considers it as a true/false alert) and to adopt a (recorded) think-aloud approach (which slows-down the analysis [42]). Then, participants motivated their choice via pre-defined answers. This is the only work we found that can be used to answer positively to RQ0.

Answer to RQ0. According to our SLR,^a only one work [29] could be said to have investigated whether real *SOC practitioners* can correctly *explain the decisions* they make. However, this study [29] was conducted to assess a proposed tool, considered only 4 SOC analysts, and the justifications had to be provided via think-aloud mechanism (which increases the cognitive load and influence the analysis [42]) and pre-defined answers (which may lead to bias [16]).

^a We also applied the snowball method [61], checking for papers cited, or cited by, the aforementioned works. Despite finding other relevant papers (e.g., [22,57]), we were unable to find other works that could support a positive answer to RQ0.

Our work builds upon that of [29]. Specifically, we will examine if employees of a single SOC, when faced with high-stakes decisions such as whether to consider an alarm as a false or true positive, can *(i)* make the correct choice, and *(ii)* justify their choice via open-text answers [12]. Importantly, we acknowledge that focusing on a single SOC prevents deriving generalizable conclusions—which is why we do not make such a claim. However, we believe that our contributions are useful to *(a)* inspire future work to carry out similar studies; and *(b)* provide evidence of how well some SOC practitioners can handle their routine tasks—which entail interacting with state-of-the-art production systems.

3 Methodology

We describe the approach used to investigate how well SOC analysts triage alarms and justify of their decisions. We utilize a controlled field experiment, carried out in a real SOC, entailing structured questionnaires and qualitative analysis. We aim to obtain factual evidence of SOC analysts’ decisions in conditions mirroring operational environments, thereby enabling to answer our RQs.

An important remark is that our study was devised in close collaboration with the examined SOC. This ensured that the setup aligned with the operational environment, thereby increasing the ecological validity of our study (We will discuss the implications of this peculiar characteristic of our study in §5.1)

3.1 Study Design Overview

Our methodology follows a mixed-methods design consisting of two components: the definition of a realistic SOC case environment (which we discuss in §3.2); and a practical alarm-classification exercise, enriched with a pre- and post-exercise questionnaires (explained in detail in §3.3). Our approach hence resembles the one in [29,32], with the difference that our study does not revolve around validating a new “tool/solution”, rather, our study is grounded in the operational workflow of a real-world SOC (from both a data and system perspective).

At a high level, the considered SOC leverages state-of-the-art appliances, including a SIEM platform that aggregated reports from various log sources. From this environment, we derive a set of representative alarms (which we denote as *cases*) that encode varying degrees of difficulty, contextual complexity, and ambiguity. Alarm selection was guided by three criteria: diversity of underlying causes (e.g., benign processes, misconfigurations, scanning activity); variation in contextual dependencies; and mixed explainability challenges, ranging from trivial to essentially ambiguous alerts. This design allows us to isolate differences in analysts’ abilities to detect false alarms and articulate correct reasoning. Yet, given the space of use cases that can occur in a SOC, we anticipate that any selection (for the sake of our study) cannot ensure complete coverage.

For time-related reasons (further detailed in §3.3), we ultimately decided to include six *cases* in our study, summarized in Table 1. Such a selection was carried out qualitatively by two researchers: one with access to domain-specific

Table 1: **Summary of the Six Cases of Alerts included in our Study.** Brief description: *Case-1*: Scheduled vulnerability scan triggered alarms. *Case-2*: Firewall allows specific developer traffic. *Case-3*: DNS sinkhole detects C&C traffic; connection blocked. *Case-4*: HTTP redirect to `msftconnecttest` misclassified as suspicious. *Case-5*: WiFi client triggered alert due to network instability. *Case-6*: Endpoint protection quarantined infected file. (More details in our repository [1])

Case	Category	Alerts	Logged Events	Alert Type	Key Observables	Source	Action / Indicator
1: Network scan by internal system	False Positive - trivial (with context) / relevant (without)	15	2,034 over 4h	Port scanning / suspicious network activity	IP source, IP destination, hit count, firewall action	Internal IP (Nessus server)	Accept; system role identified in asset database
2: Developer activity triggering alerts	False Positive - trivial	4	1,340 over 48h	Outbound connections from internal IPs	IP source, IP destination, hit count, protocol, firewall action, category, properties	Internal developer-segment IPs	Accept; triggered by developer-specific firewall rule
3: Outbound C2 communication	True Positive	1	2 over 10h	Outbound connection to Command & Control server	IP source, IP destination, hit count, firewall action, malware action	Internal host	Prevent; DNS trap and malware action confirm C2 activity
4: Windows connectivity check	False Positive - trivial	2	31,518 in 24h	Outbound HTTP/S traffic to connectivity-check URL	IP source, IP destination, hit count, protocol, firewall action	Internal load balancer	Pass; traffic to <code>msftconnecttest</code> incl. HTTP redirect
5: Internal retransmission classified as malicious	False Positive - relevant	1	2 in 2h	Internal retransmission pattern flagged as malicious	IP source, IP destination, hit count, protocol number, detected host, domain, action, reason	Internal dynamically assigned WiFi IP	Block; triggered because IP source belongs to WiFi pool
6: Malicious PowerShell script	True Positive	1	2 in 20h	Endpoint protection alert: suspicious PowerShell script	Hit count, detected host, host, domain, user, label, reason	Endpoint (self-reported)	File blocked & quarantined; virus label, affected file, external-account username

operational knowledge of the SOC, and one independent researcher, who acted as a validator for the selection. Collectively, our *cases* encompass over 30k events which triggered 24 alarms in total. Recall that, for RQ2, we want to see if certain alarms are harder to triage: therefore, choosing *cases* that – according to our own judgment – are more complex should serve to question such an hypothesis, which we can test both by measuring the rate of correct answers, but also via the follow-up questionnaire. This is why some *cases* in Table 1 are marked as “trivial”, meaning that a SOC analyst should quickly infer that the alarm is not indicative of a security-noteworthy event. On the contrary, other *cases* are marked as “relevant” because making such a decision requires carrying out additional analyses to obtain more contextual information.

After defining the *cases* (further described in our repository [1]) and after recruiting the participants (we report some demographic details in Appendix A.3), we administered the user study (in April 2025) and analysed the results.

3.2 Technical Environment (SOC Description)

We conducted our study in a SOC operating in the DACH (German-Austrian-Swiss) area; for confidentiality, we cannot provide extensive details. Companies in this geographical location are constantly under cyberattacks [20,19,54], meaning that our considered environment can serve as a proxy for SOC in other areas.

The SOC’s architecture resembles that described in §2.1. The SOC monitors a hybrid IT/OT environment that includes heterogeneous network segments, Windows and Linux endpoints, perimeter firewalls from multiple vendors, industrial controllers and several business-critical applications. All these systems continuously generate audit, network, and security telemetry. This data is sent to a central SIEM platform via standardized interfaces (e.g., syslogs).

The SIEM constitutes the analysts’ primary work environment. It runs the production correlation pipeline that consists of data normalization, enrichment, rule-based matching and temporal correlation. We did not add any experimental rules. All the alarms that were used in the exercise were triggered using the standard rule set, which is operated in daily business. This ensures that the applied *cases* reflected typical data quality, data volume, enrichment depth, and alert semantics that is encountered during regular operations (unlike the synthetic setup in [65,66], using data from elsewhere).

The SOC uses a layered tool stack that consists of (i) the SIEM for raw-data inspection and correlation logic, (ii) a dedicated case-management platform where alarms are triaged and documented, and (iii) an internal asset database that provides contextual information such as device roles, network segments, ownership and previous activities. During the study, participants received the same access rights and data views that they use in routine operations. We did this without introducing any additional filters, hints or experimental artifacts (which, perhaps unconsciously, could influence participants’ responses [29,32]).

Our technical environment thus ensured that participants’ decisions are shaped by the same constraints, information structures and tooling conditions of their routine SOC environment. The six addressed *cases* (in Table 1) were extracted from this ecosystem without modifying event semantics, field names, or rule logic. Moreover, all *cases* were derived from alerts that had occurred in production and had been processed through the standard normalization, enrichment, and correlation pipeline. Moreover, we considered *cases* that (i) occurred weeks before the field study, thereby ensuring that participants would not remember them; but which (ii) were still affected by the same infrastructure, thereby ensuring that the corresponding ground truth did not change.

Raw log entries associated with each alert were exported together with the correlated event groups that the SIEM generated at the time of detection. During preparation, sensitive fields (e.g., internal hostnames, user identifiers, customer-related data) were anonymised according to the company’s data-protection guidelines. We preserved the structural characteristics required for triaging, including timestamps, alert metadata, correlation fields and observable attributes.

Each *case* was validated against the operational incident documentation and the asset database to confirm its factual ground truth. This ensured that both true positives and false positives reflect real underlying causes and not synthetic constructs. Importantly, sanitization process did not alter the semantic content of the logs or introduce potential artifacts that could non purposely guide analysts. The final *case* sets were prepared in a way that maintained the full analytical complexity of the original alerts. Additionally, they met all internal confidentiality and data-protection requirements.

3.3 Study Implementation and Ethics

Participant Recruitment. In April 2025, we recruited 12 full-time security analysts that work in the same SOC environment. Participants were of various

experience levels, ranging from junior to senior analysts. Participation was completely voluntary, and there was no identifiable information collected. The study was carried out during the participants’ regular working hours. We quantified the total time that each participant would spend for our study in roughly 3 hours, of which 2 were spent on the day of the exercise, and another hour would be spent for logistics and communication. To better reflect operational contexts and to minimize time waste, the study was done synchronously (on site) and in groups, but participants could not communicate to each other. This ensured that their decisions could be attributed to personal reasoning. Importantly, the employer company had been made aware of our study, and the overall design and implementation complied with the SOC’s internal standards (confirmed by their management). We report in the Appendix [A.2](#) additional ethical considerations.

Pre-study phase. The study begins with a ≈ 45 minutes preparatory session during which participants are explained the objectives and procedure of the study. This included an explanation of what to expect over the next two hours, and which systems are available for processing the tasks (e.g., the SIEM). Organizational framework conditions were also discussed, including the planned time structure, instructions on behavior during the study and how to deal with open questions. A compact introduction to the systems was given, in which the most important functions relevant to case processing were explained. Finally, the technical setup was reviewed and tested and any final questions were clarified. After this preparatory phase, the participants were given access to a preliminary questionnaire (entirely reported in our repository [\[1\]](#)), through which we could record participants’ previous experience, skills and assessments with regard to alarm analyses. The average time taken to complete the initial questionnaire was around 15 minutes. The aggregated results are provided in Appendix [A.3](#).

Practical Classification Exercise. Participants were given a cheat sheet containing the key information to support the analysis. The duration of the exercise was set to 30 minutes: this served to infer how well each participant would perform in a limited timespan (roughly, 5 minutes per case). We report all cases in detail in Table [1](#). For each case, participants performed two tasks: classification (they had to decide whether the case represents a true or false positive) and justification (they had to provide a free-text explanation that includes the rationale behind the classification). For the latter, and crucially, participants should have known how to properly justify each answer (both because of their prior expertise, but also because of the preliminary phase). Each case consisted of sanitized log data and contextual information extracted from the real SOC environment. The presentation mirrored the information flow that analysts experience during daily operations, including correlated events, timestamps, and relevant system attributes. We ensured that participants could access all information necessary to resolve a case (though usage of AI was prohibited, since it is also not part of the SOC workflow), and participants were reminded at regular intervals to move on to the next case if they were finding a case particularly challenging. Participants were not informed about the number of true/false positives. With

the exception of one participant (who required 18 minutes), all participants took the entire 30 minutes to complete the exercise.

Post-study phase. After the main exercise, participants were shown a survey asking open questions about the complexity of the cases, decision making, and time efficiency. The entire questionnaire is reported in our repository [1]. The focus was on identifying influencing factors that have a positive or negative impact on the efficiency and accuracy of the analysis. Roughly 30 minutes were taken to complete this questionnaire. Finally, after reviewing the results, we communicated them to participants and asked for (unstructured) feedback.

3.4 Qualitative Coding Approach

We are not aware of prior studies with a scope similar to ours. Given the unstructured nature of the justifications, we adopted *hybrid coding* approach, mostly reliant on inductive reasoning, but for which we followed high-level guidelines.

Coders. Three reviewers (R1, R2, R3) participated in the qualitative assessment. R1 had access to contextual information provided by the participating SOC, enabling accurate interpretation of explanations; R2 is a security researcher with a decade of experience in this research domain, and who also has SOC work experience (in a different SOC); R3 is a security researcher with >5 years of experience in the operational security research domain. Importantly, R1 and R2 also contributed in the selection of the six cases considered in our study.

Workflow. After administering the study, the responses were first inspected by R1: for this preliminary assessment, R1 interacted with R2 to determine how to handle specific occurrences (e.g., “what if a participant writes ‘no more time’ in the open-text? Should it count as a ‘N/A’ or as a wrong answer?”). Then, the coders used their own judgment to assign their codes to the responses. To avoid bias, R3 *never interacted* with R1: R3 only used the detailed information on each case (reported in the supplementary material). With regard to R2, given that the study was done in German (the language of the SOC), machine-generated translations were provided to guide the assessment (whereas R1 and R3 are fluent in German). Once all coders assigned their codes, the opinions were compared, showing that coders were generally in agreement (there was consensus in 82% of the codes). Discrepancies were resolved via synchronous and asynchronous communication, with R2 acting as middle point. Decisions were finalized in a final meeting between R1 and R2, during which some initial codes by R1 changed. Hence, even though R1 had the final call, the collective contribution of all coders was essential to maximise interpretative quality and derive accurate results.

Guidelines. To assign codes, we established two rules: first, an answer was treated as “N/A” if it was left empty or if provided no form of technical assessment (e.g., “no time”); second, if the alert was classified incorrectly, then the explanation is never considered as correct (to avoid biasing our results).⁵ Then, each coder used their own judgment to assign codes. At a high-level, when analysing each response, we sought to answer two questions: (a) “does the

⁵ We still inspected these answers, confirming our choice (explanations were not valid).

Table 2: Distribution of classification-explanation result types across all participants.

Classification	Explanation	n (72)	%
Correct	Correct	22	31%
Correct	Incorrect / Vague	35	48%
Correct	Missing	3	4%
False / Missing	–	12	17%

text show understanding of the reason why the alarm was classified in a specific way?” and (b) “is the explanation of use to another security analyst?”. A positive answer to either of these two questions would typically lead to a valid explanation (✓). This is because we are not merely interested in determining if, e.g., the answer is “just” correct,⁶ rather we want to see if the analyst is aware of what is going on in the monitored environment. We note that participants were explicitly told to be as specific as possible when motivating their decisions.

4 Results

We first examine the relationship between analysts’ classification performance and their ability to provide accurate and technically grounded justifications (§4.1). Finally, we investigate differences in the difficulty of evaluating false positives (§4.2).

4.1 Accuracy and Quality of Analysts’ Explanations (RQ1)

We provide the results on the relationship between participants’ classification decisions and corresponding justifications. Classification represents the correctness of the final decision (true/false positive), while justification refers to providing a valid explanation that describes the actual technical cause of the alert. We recall (§3.3) that participants were given clear instructions (and should also have known) about how to justify their choices.

Overall Performance Patterns. Across all six cases and 12 participants (72 total decisions), we identified four distinct outcome types. As shown in Table 2, 22 decisions (31%) included both a correct classification and a correct explanation; 35 decisions (48%), represented correct classification but incorrect or incomplete explanation, whereas 3 (4%) decisions were correct but no explanation was provided. Finally, the remaining 12 (17%) were misclassified or skipped. These findings suggest a misalignment between recognizing the correct outcome and being able to justify that outcome. Even though 60 (out of 72, i.e., 83%) cases were classified correctly, an appropriate explanation was given only in 37% of these cases (i.e., 22 out of 60). Based on this result, we argue that analysts’ judgments are driven by intuition, experience or heuristics, and not by explicit reasoning—or, if so, then analysts cannot properly convey such a reasoning.

⁶ Recall that our goal is determining if SOC analyst can motivate their decisions—which implies that the explanation should explain why a given alert was deemed as an FP or TP. For instance, for TPs, an explanation stating “this is suspicious” is not acceptable because it does not have any practical utility; whereas, for FPs, an explanation stating “everything is normal” would also be deemed as invalid, since it is obvious that “everything is normal” if an alert is considered an FP.

Fine-grained Analysis. We report in Table 3 the fine-grained distribution of classification (“C”) and explanation (“E”) across all cases and participants; ✓ and ✗ denote correct and incorrect answers, whereas □ denotes cases with no answer. Let us discuss some interesting findings related to specific cases.

- *Case 1*, which represents a scheduled Nessus vulnerability scan, was the only case for which all 12 participants produced correct classifications. In addition, eight participants provided a correct explanation by drawing on information from the asset database and the scanner’s unique identifier. The high explanation correctness rate shows that analysts can provide appropriate reasoning when alerts exhibit a single technical artifact (all coders agreed on this).
- *Case 2* highlights the main difficulty that strongly relates to RQ1. Regardless that 11 participants classified the case correctly, only one provided an appropriate explanation. Most answers did not express understanding of the reason why the case was a false alert. We posit that this shows that humans make correct guesses because something feels normal (some participants explicitly confirmed this), but without being able to motivate the overarching reason.
- *Case-3* was correctly identified as a true positive by 9 participants, but only 5 these gave a valid explanation. In some instances, the explanation simply reported the name of the alert itself (i.e., “Suspected Botnet”) or was a copy-paste of the SIEM’s output, both of which being not appropriate explanations.
- *Case 4* and *Case 5* also demonstrate poor explanatory performance. *Case 4*, which involved misclassified Windows connectivity checks, required that analysts identify that the large volume of HTTP redirects was benign. 9 participants recognized this, but only two correctly explained why. Many explanations mentioned traffic regularity but ignored the `msftconnecttest` domain, which was central to the ground truth⁷. In *Case 5*, which involves dropped WiFi retransmits, explanations were even weaker. Regardless that nine participants arrived at the correct false positive classification, justifications frequently used irrelevant proxy events or false assumptions about user behavior.
- For *Case-6*, an appropriate explanation was given only by 4 out of 10 participants that correctly guessed the alert was a true positive. Among the not satisfactory explanations, some participants stated “the tool was recognised as malicious by the EDR” which is true, but not informative because the same logic can apply for any alert raised by the security system. In contrast, valid explanations provided more insight about why the alert deserved further scrutiny (e.g., one stated “it is a PowerShell script from Edge, so it is suspicious”, thereby expanding the information provided by the security system). (We report in Appendix A.4 some examples of how we coded some responses)

Individual Reasoning Patterns. To better understand our results, we looked at the answers in the post-study questionnaire. We hypothesize that differences in explanation quality cannot be attributed solely to experience or technical background. Indeed three top-performing participants (P4, P6, P7) had different prior roles (in IT support, networks, software development). However, their

⁷ `msftconnecttest` is legitimate Windows Network Connectivity Status Indicator traffic, but in this case the host generating it should never have done so (a true alarm).

Table 3: Per-Participant Classification and Explanation Results Across All Cases

Participant	Case 1		Case 2		Case 3		Case 4		Case 5		Case 6	
	C	E	C	E	C	E	C	E	C	E	C	E
P1	✓	✓	✓	□	✓	✓	✓	✗	✓	✓	✗	✗
P2	✓	✗	✓	✗	✓	✗	✓	✗	✓	✗	✓	✓
P3	✓	✓	✓	✗	✗	✗	✗	✗	✗	✗	✓	□
P4	✓	✗	✓	✗	✓	✓	✓	✗	✓	✗	✓	✓
P5	✓	✓	✓	□	✗	✗	✓	✗	✓	✗	✓	✓
P6	✓	✓	✓	✗	✓	✗	✓	✓	✓	✗	✓	✗
P7	✓	✓	✓	✗	✓	✓	✓	✗	✓	✓	✓	✓
P8	✓	✓	✓	✗	✓	✗	✗	✗	✗	✗	✓	✗
P9	✓	✓	✓	✗	✓	✓	✓	✗	✓	✗	□	□
P10	✓	✓	□	□	✓	✗	✓	✗	□	□	✓	✗
P11	✓	✗	✓	✗	✗	✗	✓	✓	✓	✓	✓	✗
P12	✓	✗	✓	✓	✓	✓	✓	✗	✓	✗	✓	✗
Correct	12	8	11	1	9	5	9	2	9	3	10	4

performance cannot be attributed to their domain-specific expertise (which, in theory, also other participants had) but to their approach. These participants: (i) referenced multiple log fields; (ii) triangulated between SIEM data and the asset database; (iii) searched for related patterns rather than isolated events; and (iv) provided detailed reasoning (e.g., “Hack tool in the name + Strange user → Pentest from {redacted}” referring to Case-6).

In contrast, the three lowest-performing participants (P3, P8, P10) demonstrated very different behaviors. One participant submitted answers rapidly (18 minutes out of 30 available, denoting that time was not a factor), expressed high confidence, but did not look at the detailed fields within each alert, such as IP addresses, domains or log attributed. One explanation stated “action was prevented, it is OK”. Another participant expressed persistent uncertainty and confusion: accordingly, this was due to difficulties in managing the cognitive load of the SIEM-like interface—despite such interface being the one used in the SOC.

We also found that participants expressing high confidence not necessarily provide highly-accurate explanations. This was also the case for the experience level. For example, a participant with more than ten years of IT experience produced one of the weakest reasoning. On the other hand, a participant with low self-rated SOC ability was able to produce several correct and usable explanations. This shows that explanatory competence is a distinct analytic skill and not a byproduct of technical experience or classification accuracy.

Information Availability vs. Accessibility. A frequently mentioned source of uncertainty (in the post-study questionnaire) was “missing information.” However, nearly all information participants requested, which often includes system roles, IP ownership, and port information, was fully available directly in the logs or in the asset database. What seemed to be missing was not information, but the analysts’ ability to find, filter, and process such information under time pressure. This indicated that analysts often struggle with dealing with large volumes of data. Hence, we conjecture that wrong or missing explanations are the result of difficulties in structuring information rather than from a lack of data.

Answer to RQ1: Our results show a disconnect between analysts’ ability to classify alerts correctly vs. their ability to provide correct and evidence-based explanations for their decisions. Correct classifications were guided by intuition rather than by the identification and articulation of the technical indicators.

4.2 Differential Difficulty Across False Positive Types (RQ2)

Our second RQ investigates whether certain types of false positives are more difficult to evaluate and what characteristics make these cases challenging.

Contextual Differences in Performance. We refer to Table 3, showing the classification accuracy per case (“C” column). The results show substantial variations. For instance, all twelve participants correctly classified *Case 1*, while only nine classified *Cases-3-4-5* correctly. The differences can hardly be explained via randomness:⁸ each case is semantically different (see Table 1). Cases can be grouped according to structural features: (a) clear false (*Case 1*) and true (*Case 6*) positives involved distinct signatures (e.g., known scanner identity and malware quarantined by EDR), which required minimal contextual inference; (b) context-dependent false positives (*Case 2*) depended on internal business logic not encoded in the log data, and required further investigation or knowledge to be properly explained (c) ambiguous and mixed-signal false positives (*Case 4*, *Case 5*) required cross-field correlation and interpretation of indicators distributed across the dataset, which makes them the hardest to explain and least reliably classified; whereas (d) true positives with distributed indicators (*Case 3*) required participants to correlate information across multiple log fields to reconstruct the blocked C&C communication attempt, wherein classification accuracy was relatively high and explanation quality varied.

Structural Characteristics Driving Difficulty. We identified a set of structural alert features that consistently influenced both classification accuracy and explanation quality: (1) *Indicator Dispersion*: cases with indicators spread across multiple log fields (e.g., *Case 5*) showed higher cognitive load. Participants had to synthesize information such as timestamps, IP relationships, behavior indicators, and log-source metadata. Several participants failed to understand these signals, which lead either to misclassifications or correct classifications with incorrect explanations; (2) *High Log Volume*: *Case 4* contained over 31,000 events, which is much larger compared to other cases. While the cause (Windows connectivity tests) was considered benign, the large volume increased perceived complexity. Participants showed uncertainty regarding which events were relevant, which lead to them focusing on irrelevant fields; (3) *Contextual Ambiguity*: Some false positives required organizational knowledge, which is not part of the alerts themselves. *Case 2* demonstrates that correct classifications were common

⁸ A binomial stat test reveals ($p < .05$) that participants are not answering randomly. Moreover, comparing, e.g., *Case 1* and *Case 3* with a McNemar’s test shows that if the two cases were equally difficult, then results at least as imbalanced as observed would occur $\approx 8\%$ of the time. The same holds for, e.g., *Case 1* and *Case 4* (or 5).

but explanations were almost always incorrect. This shows that contextual false positives are still difficult to deal with even in cases when technically trivial; and (4) *Similarity to Attack Patterns*: false positives that represent real attacks (e.g., retransmissions or unusual domain redirects) created hesitation among participants. They frequently misinterpreted harmless behavior as threatening unless an anchor (e.g., scanner identity, benign domain reputation) was obvious.

Cognitive and Organizational Factors Relevant to Difficulty. Several cognitive and environmental factors also influenced perceived difficulty. Time pressure was the reason the analysis was cut short, which led analysts to fixate on initial indicators. Furthermore, participants stated that tool navigation challenges made it difficult to identify relevant fields even when visible. This was also the case with mental models of the network, which led participants to misinterpret IP relationships or misunderstand system roles. Finally, heuristic shortcuts often replaced systematic reasoning, particularly in unclear cases. Note that such feedback was not meant as a critique to our study setup, but rather, to the overarching problem of routinely triaging alerts in their SOC.

Cross-Participant Patterns. The experiences of top and bottom performers further elaborated case difficulty. Top performers recognize case structure early and adjust their strategy accordingly. Bottom performers relied on single-field inspection or their prior experiences. Interestingly, participants with high IT experience struggled with contextual cases. This suggests that the reason behind this difficulty are the properties of the alert and not analysts themselves.

Answer to RQ2: Across our six cases, there is a substantial difference in the classification correctness of our participants. Our results suggest that triaging certain alarms requires different mental load: some alerts offer clear technical anchors, while others require complex and often contextual interpretation. Triage became challenging when relevant indicators were not evident (e.g., spread across multiple log sources, or embedded in high-volume data). These characteristics reduced analysts’ ability to classify (and explain) alerts reliably.

5 Discussion and Implications

5.1 Lessons Learned and Limitations

Lessons Learned. We identify three major takeaways.

- Our study suggests that our analysts’ decision-making processes are shaped based on the provided information rather than by the complexity of its the root causes. Several cases demonstrated that even routine false positives became difficult in cases when contextual cues were scattered, incomplete or presented in a format that required significant manual efforts and reconstruction. On the other hand, technically complex alerts could be handled reliably whenever relevant attributes were “obvious” and provided to the analysts in a coherent way. Thus, we argue that the practical bottleneck in SOC triage is not the volume of data, but how the data is organized and presented.

- A second lesson learned relates to time management. Most participants reported that the allotted time was not enough (although two said otherwise), which impacted their performance. This is a valid observation. Yet, time management is a crucial component in SOC. In fast-paced environments, such as SOC, it is imperative to make decisions quickly (and accurately). The fact that some cases required “more time” highlights *(i)* that some alarms are harder to triage—supporting RQ2; but also *(ii)* that the way information is provided to the analyst is not optimal. Nonetheless, after receiving feedback, some participants stated they learned new knowledge from this exercise.
- The third lesson learned stems from the fact that, in our study, no AI-driven assistance was received. More specifically, the considered SOC, at the time of our study, did not have operational AI-powered systems (e.g., RAG or LLMs). Moreover, in the pre-study questionnaire, five participants stated that “they use AI but feel unsafe doing so”, whereas the remaining seven stated that they do not use AI (although five reported they are unsure of whether AI is useful in their context). We believe that such a divergence underpins an operational dilemma: AI could be used to better organize the information scrutinized by the analyst, but analysts themselves do not (at the time of our study) see AI as a trustworthy assistant—at least for security-sensitive tasks.

Limitations. We discuss potential critiques that could be made to our research.

- *SLR.* The paper-collection phase of our SLR was done by one author who double checked the results, whereas the qualitative analysis was done by two authors to minimise bias and increase correctness. Our search queries should be specific enough to capture all works relevant to answer RQ0, but to avoid missing relevant works we also checked if, among the references in the considered papers, we could find titles that indicated works relevant for RQ0. To the best of our knowledge, our SLR is exhaustive.
- *Sample size.* It would be unfair to criticize our study for the “small sample size”. It is well-known that publicly-available and up-to-date information on how SOC are run internally, as well as what data flows through their SIEMs and what alarms are triggered, can hardly be found. Indeed, SOC-related research is mostly driven by direct collaboration with operational SOC [59,5,29]. Such studies are, therefore, particularly challenging to carry out—because finding agreements with professionals is not simple in the general sense [28,25], and particularly so when the subject of discussion is security-sensitive content. Consequently, user studies in a SOC setting are relatively small scale see our repository [1]. In contrast, in other domains (e.g., phishing) valid participants can be regular employees [4] or internet users [64], enabling a broader coverage and facilitating generalizations. The size of our sample (12) aligns with the average of extant literature, and our sample is larger than that of the closest work [29] (which has 4). As we wrote (§2.3), we do not claim generalizability.
- *Selection of Cases.* In designing our study, we were time-constrained. Given that each participant had to partake in a debriefing phase, as well as in the pre-/post-questionnaires (which required ≈ 90 minutes altogether), we could not put dozens of cases. This inevitably forced us to handpick a select number of

cases that exhibited enough variety to answer our RQs. We acknowledge that our selection may have been driven by subjectivity. However, given that we are not claiming generalizable results, we do not believe that our choices would threaten the validity of our conclusions. Nonetheless, we provide additional information on selected cases in our repository [1]: such information can be useful to future work for designing studies similar to ours.

- *Individual setting.* Analysts were required to work without interacting with colleagues, which is a common practice in SOC workflows. We isolated individual reasoning to avoid cross-influence, but this also removes the social mechanisms (e.g., discussion, verification, escalation) that mitigate uncertainty. In regards to the provided explanation, these were deliberately open-ended (to differentiate from [29]). The downside is that correctness assessment dependent on qualitative (mostly inductive) coding. To mitigate this, we adopted a three-party reviewing system (see §3.4), which also involved the cooperation of the examined SOC, before drawing our conclusions.
- *Trustworthiness.* A tacit assumption is that our participants carried out this exercise faithfully. All participants were properly debriefed on the expectations of our study (and we were available to provide guidance during the exercise), but we had no control on whether participants truly did their best in our field exercise. For ethical reasons, there was no incentive in performing well.

Finally, we reiterate that this work was done in cooperation with the examined SOC. This peculiarity substantially increased the ecological validity of our study: first, because of the selection of appropriate *cases* and the overall design of the experiment; second, because of the qualitative evaluation. Indeed, discrepancies among coders were resolved by reviewing the examined SOC’s specific context. Importantly, the major findings of our work go against what would be expected of any SOC’s desiderata (i.e., the fact that analysts cannot properly explain their decisions can be seen as a weak point), which is why we argue that our results are not biased/affected by potential conflicts of interests.

5.2 Positioning within Extant Work

Prior studies (e.g., [5,36,46]) have primarily examined analysts’ practices at a conceptual or procedural level (e.g., mapping workflows, documenting cognitive challenges or highlighting organizational constraints). These works provide broad insights into how analysts report making decisions but they do not characterize how well analysts reason about alerts when provided with the concrete technical evidence. Hence, we focus not on perceived obstacles or self-reported strategies, but on the observable reasoning behavior when practitioners engage with real alerts from their operational environment. This shift from descriptive accounts to empirical evaluation allows for better understanding of SOC decision-making.

Earlier evaluations that included participants in hands-on tasks, such as the simulations in [65,66] or the alert relevance assessments in [32], focused on whether participants could identify suspicious activity. These studies aim to showcase analysts’ general ability to detect threats. However, they do not examine how analysts formulate their interpretations. In contrast, our work uncovers a

remarkable difference between selecting the correct classification and articulating a technically accurate explanation. This distinction matters because SOC workflows depend not only on correct decisions but also on coherent documentation for handovers, incident reports and auditability. These are all components that, to our knowledge, prior studies did not empirically measure.

Let us compare our findings with those of Kersten et al. [29], whose field exercise included 10 alerts, each analysed by 4 analysts. Out of 40 responses, 36 were correct (all subjects correctly classified 9 out of 10 alerts). Of the 4 misclassifications, 3 were for “interesting” alerts, which implied more complex cases to triage; these results somewhat align with ours. Overall, the median time to investigate an alert was 10 minutes; however, the authors of [29] state that “It is likely that SOC analysts analyze these incidents faster in the SOC than in our experiment as we employed a think-aloud protocol”, thereby explaining why participants took more time than in our study. We could not find specific details about the correctness of the explanations. However, and crucially, we cite the following excerpt: “we found that all errors but one were due to differences in the experiment setup from the operational setup the analysts are used to.”

5.3 Recommendations

The topmost pain-point mentioned by our participants refers to the way information is presented. Hence a recommendation is to **improve data presentation/visualization** (e.g., [58]). This can be achieved by consolidating key indicators, contextual attributes and historical data within SOC platforms. Such a suggestion can also encompass automated enrichment processes (e.g., embedding asset metadata, known business processes or recent infrastructure changes directly into the alert) as well as explainable-AI techniques (e.g., [59]).

Furthermore, **we recommend SOC engage in activities similar to those in our work**. The poor performance of our participants may also stem from a lack of experience in explaining decisions in an open-text format. It is possible that analysts knew the reason why an alert was (or not) an FP, but they formulated their thoughts poorly. More frequent “explanation-based” exercises could reinforce the analysts’ abilities to communicate their operational decisions.

Finally, the difficulty of triaging different alarms can vary significantly. As a result, SOC improvement efforts should not treat all alerts equally. Instead, alerts that repeatedly caused uncertainty (e.g., those requiring cross-system correlations or business knowledge) should be prioritized. This could include **adjusting SIEM rules, improving documentation, or integrating clearer contextual indicators**. Moreover, an argument can also be made on the importance of *periodic review sessions*, which can be used to retroactively identify the most common “trivial” or “relevant” alerts are encountered by analyst.

6 Conclusions

Our real-world field study with 12 SOC analysts shows that while analysts generally make correct triage decisions, they often struggle to explain them. We used

six operational alarm cases drawn directly from the SOC’s production environment, wherein we observed that 83% of classifications were correct. However, only fewer than half of the explanations aligned with the true root cause. Some of the alarms were harder to reason about, regardless that analysts had a full access to the standard SIEM, case-management tools and asset context. This indicates that the core challenge lies in interpreting and articulating context rather than the availability of data. Our findings expose a practical risk for SOC operations, where transparent decision-making is of utmost importance.

Future work can use our experimental approach and findings to carry out similar studies in similar (or different) SOC’s. We cannot claim that the analysts of all SOC’s are unable to provide the right justification. Yet, our SLR showed that limited attention has been given to such a pivotal aspect of a SOC’s workflow. More research is needed to further explore this operational dimension.

Acknowledgment. We thank the participants of our field study for the time they invested in this effort. We also extend our thanks to the DIMVA PC for the great feedback. Parts of this research was funded by Hilti.

References

1. Repository of this paper. https://github.com/hihey54/dimva26_soc
2. Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union. Official J. of the European Union (2016)
3. Commission Delegated Regulation (EU) 2024/1366 of 11 March 2024 supplementing Regulation 2019/943 of the European Parliament and of the Council (2024)
4. Acharya, B., Vadrevu, P.: A human in every ape: Delineating and evaluating the human analysis systems of anti-phishing entities. In: DIMVA (2022)
5. Alahmadi, B.A., Axon, L., Martinovic, I.: 99% false positives: A qualitative study of {SOC} analysts’ perspectives on security alarms. In: USENIX SEC (2022)
6. Apruzzese, G., Laskov, P., Schneider, J.: Sok: Pragmatic assessment of machine learning for network intrusion detection. In: IEEE EuroS&P (2023)
7. Araujo, I., Vieira, M.: Enhancing intrusion detection in containerized services: Assessing machine learning models and an advanced representation for system call data. *Computers & Security* (2025)
8. Bailey, M., Dittrich, D., Kenneally, E., Maughan, D.: The Menlo report. *IEEE S&P* (2012)
9. Burda, P., Allodi, L., Serebrenik, A., Zannone, N.: ‘protect and fight back’: A case study on user motivations to report phishing emails. In: EuroUSEC (2024)
10. CheckPointResearch: (2025), <https://blog.checkpoint.com/research/global-cyber-attacks-increase-in-november-2025-driven-by-ransomware-surge-and-genai-risks/>
11. Cho, S.Y., Happa, J., Creese, S.: Capturing tacit knowledge in security operation centers. In: HAISA (2020)
12. Choi, B.C., Pak, A.W.: A catalog of biases in questionnaires. *Preventing chronic disease* (2004)
13. Chung, M.H.M.: Interactive Machine Learning in Cybersecurity: Using Human Expertise More Effectively. Ph.D. thesis, University of Toronto (Canada) (2023)

14. Clearnetwork: Security operations center best practices for small and medium enterprises (smes) (2025), <https://clearnetwork.com/security-operations-center-best-practices-for-small-and-medium-enterprises-smes/>
15. Colelli, R., Panzieri, S., Pascucci, F.: Securing connection between it and ot: the fog intrusion detection system prospective. In: IEEE MetroInd4.0&IoT (2019)
16. Connor Desai, S., Reimers, S.: Comparing the use of open and closed questions for web-based measures of the continued-influence effect. Behavior Res. Meth. (2019)
17. DeepStrike: Top10 targeted countries for cyber attacks (2025), <https://deepstrike.io/blog/top-10-countries-most-targeted-by-cyber-attacks-in-2025>
18. Eriksson, H.S., Grov, G.: Towards xai in the soc—a user centric study of explainable alerts with shap and lime. In: IEEE Big Data (2022)
19. EY: Cyberattacks and data theft (2024), https://www.ey.com/de_at/newsroom/2024/11/cyberangriffe-datendiebstahl, accessed: December 13, 2024
20. Federal Office for Information Security: (2024), https://bsi.bund.de/DE/Service/Navipublikationen/Lagebericht/lagebericht_node.html
21. Franklin, C., Ballan, M.: Reliability and validity in qualitative research. The handbook of social work research methods (2001)
22. Garneau, C.J., Erbacher, R.F., Etoty, R.E., Hutchinson, S.E.: Results and lessons learned from a user study of display effectiveness with experienced cyber security network analysts. In: LASER (2016)
23. Goodall, J.R.: Defending the network: Visualizing network traffic for intrusion detection analysis. Ph.D. thesis, University of Maryland, Baltimore County (2007)
24. Hagen, R.A., Øverlier, L., Helkala, K.: Human factors in ai-driven cybersecurity: Cognitive biases and trust issues. ACM DTRAP (2025)
25. Horstmann, S.A., Hong, S., Klein, D., Serafini, R., Degeling, M., Johns, M., Moon-samy, V., Naiakshina, A.: “Sorry for Bugging you so much.” Exploring Developers’ Behavior Towards Privacy-Compliant Implementation. In: IEEE S&P (2025)
26. International Organization for Standardization: Iso/iec 27001:2022 (2022)
27. Jansen, M., Bobba, R., Nevin, D.: A comparative analysis of difficulty between log and graph-based detection rule creation. In: WOSOC (2024)
28. Kaur, M., Parkin, S., Janssen, M., Fiebig, T.: “I needed to solve their overwhelm-ness”: How system administration work was affected by covid-19. CSCW (2022)
29. Kersten, L., Darré, S., Mulders, T., Zambon, E., Caselli, M., Snijders, C., Allodi, L.: A security alert investigation tool supporting tier 1 analysts in contextualizing and understanding network security events. In: ACSAC (2024)
30. Khayat, M., Barka, E., Serhani, M.A., Sallabi, F., Shuaib, K., Khater, H.M.: Empowering security operation center with artificial intelligence and machine learning—a systematic literature review. IEEE Access (2025)
31. Kokulu, F.B., Soneji, A., Bao, T., Shoshitaishvili, Y., Zhao, Z., Doupé, A., Ahn, G.J.: Matched and mismatched socs: A qualitative study on security operations center issues. In: CCS (2019)
32. Kurogome, Y., Otsuki, Y., Kawakoya, Y., Iwamura, M., Hayashi, S., Mori, T., Sen, K.: Eiger: automated ioc generation for accurate and interpretable endpoint malware detection. In: ACSAC (2019)
33. Lipnicki, P., Lewandowski, D., Pareschi, D., Pakos, W., Ragaini, E.: Future of iotsp—it and ot integration. In: IEEE FiCloud (2018)
34. Liu, H., Zhong, C., Alnusair, A., Islam, S.R.: Faixid: A framework for enhancing ai explainability of intrusion detection results using data cleaning techniques. JNSM (2021)
35. Meschini, M., Di Tizio, G., Balduzzi, M., Massacci, F.: A case-control study to measure behavioral risks of malware encounters in organizations. IEEE TIFS (2024)

36. Mink, J., Benkraouda, H., Yang, L., Ciptadi, A., Ahmadzadeh, A., Votipka, D., Wang, G.: Everybody's got ml, tell me what else you have: Practitioners' perception of ml-based security tools and explanations. In: IEEE S&P (2023)
37. Moher, D., Shamseer, L., Clarke, M., Ghersi, D., Liberati, A., Petticrew, M., Shekelle, P., Stewart, L.A., Group, P.P.: Preferred reporting items for systematic review and meta-analysis protocols (prisma-p) statement. *Systematic Rev.* (2015)
38. Nadeem, A., Vos, D., Cao, C., Pajola, L., Dieck, S., Baumgartner, R., Verwer, S.: Sok: Explainable machine learning for computer security applications. In: IEEE EuroS&P (2023)
39. Naseer, A., Naseer, H., Ahmad, A., Maynard, S.B., Siddiqui, A.M.: Moving towards agile cybersecurity incident response: A case study exploring the enabling role of big data analytics-embedded dynamic capabilities. *Computers & Security* (2023)
40. Ofte, H.J.: The awareness of operators: A goal-directed task analysis in socs for critical infrastructure. *Journal of Critical Infrastructure Studies* (2024)
41. Pekaric, I., Apruzzese, G.: "We provide our resources in a dedicated repository": Surveying the Transparency of HICSS publications. *HICSS* (2025)
42. Pike, M.F., Maior, H.A., Porcheron, M., Sharples, S.C., Wilson, M.L.: Measuring the effect of think aloud protocols on workload using fnirs. In: ACM CHI (2014)
43. Reeves, A., Ashenden, D.: Understanding decision making in security operations centres: building the case for cyber deception technology. *Frontiers in Psych.* (2023)
44. Reeves, A., Ashenden, D.: 'it's not paranoia if they're really after you': When announcing deception technology can change attacker decisions. In: *HICSS* (2025)
45. Roul, S.: Incident management in b2b payments: Challenges, frameworks, and emerging best practices. *J. Comp. Sci. Tech. Stud.* (2025)
46. Saha, A., Mattei, J., Blasco, J., Cavallaro, L., Votipka, D., Lindorfer, M.: Expert insights into advanced persistent threats: Analysis, attribution, and challenges. In: *USENIX SEC* (2025)
47. SANS: SOC Survey (2025), sans.org/white-papers/sans-2025-soc-survey
48. Schröer, S.L., Apruzzese, G., Human, S., Laskov, P., Anderson, H.S., Bernroider, E.W., Fass, A., Nassi, B., Rimmer, V., Roli, F., et al.: Sok: On the offensive potential of ai. In: *IEEE SaTML* (2025)
49. Singh, R., Tariq, S., Jalalvand, F., Chhetri, M.B., Nepal, S., Paris, C., Lochner, M.: Llms in the soc: An empirical study of human-ai collaboration in security operations centres. *arXiv:2508.18947* (2025)
50. Sopan, A., Berninger, M., Mulakaluri, M., Katakam, R.: Building a machine learning model for the soc, by the input from the soc, and analyzing it for the soc. In: *IEEE VizSec* (2018)
51. Splunk: Splunk enterprise security (2025), https://www.splunk.com/en_us/products/enterprise-security.html
52. Stevens, R., Votipka, D., Dykstra, J., Tomlinson, F., Quartararo, E., Ahern, C., Mazurek, M.L.: How ready is your ready? assessing the usability of incident response playbook frameworks. In: ACM CHI (2022)
53. Sundaramurthy, S.C., Case, J., Truong, T., Zomlot, L., Hoffmann, M.: A tale of three security operation centers. In: *ACM SIWs Workshop* (2014)
54. Swiss Cyber Institute: (2024), <https://swisscyberinstitute.com/blog/key-insights-switzerland-latest-cybersecurity-report/>
55. Tariq, S., Baruwat Chhetri, M., Nepal, S., Paris, C.: Alert fatigue in security operations centres: Research challenges and opportunities. *ACM CSUR* (2025)
56. Teuwen, K.T., Mulders, T., Zambon, E., Allodi, L.: Ruling the unruly: Designing effective, low-noise network intrusion detection rules for security operations centers. In: *AsiaCCS* (2025)

57. Thomson, R., Cassenti, D.N., Hawkins, T.: Too much of a good thing: How varying levels of automation impact user performance in a simulated intrusion detection task. *Computers in Human Behavior Reports* (2024)
58. Ulmer, A., Sessler, D., Kohlhammer, J.: Netcapvis: Web-based progressive visual analytics for network packet captures. In: *IEEE VizSec* (2019)
59. Van Ede, T., Aghakhani, H., Spahn, N., Bortolameotti, R., Cova, M., Continella, A., Van Steen, M., Peter, A., Kruegel, C., Vigna, G.: Deepcase: Semi-supervised contextual analysis of security events. In: *IEEE S&P* (2022)
60. Vermeer, M., Kadenko, N., van Eeten, M., Gañán, C., Parkin, S.: Alert alchemy: Soc workflows and decisions in the management of nids rules. In: *CCS* (2023)
61. Wohlin, C.: Guidelines for snowballing in systematic literature studies and a replication in software engineering. In: *EASE* (2014)
62. WorldEconomicForum: Global cybersecurity outlook (2025), https://reports.weforum.org/docs/WEF_Global_Cybersecurity_Outlook_2025.pdf
63. Yang, L., Chen, Z., Wang, C., Zhang, Z., Booma, S., Cao, P., Adam, C., Withers, A., Kalbarczyk, Z., Iyer, R.K., et al.: True attacks, attack attempts, or benign triggers? an empirical measurement of network alerts in a security operations center. In: *USENIX SEC* (2024)
64. Yeke, D., Ibrahim, M., Tuncay, G.S., Farrukh, H., Imran, A., Bianchi, A., Celik, Z.B.: Wear’s my data? Understanding the cross-device runtime permission model in wearables. In: *IEEE S&P* (2024)
65. Zhong, C., Yen, J., Liu, P., Erbacher, R.F., Garneau, C., Chen, B.: Studying analysts’ data triage operations in cyber defense situational analysis. In: *Theory and models for cyber situation awareness* (2017)
66. Zhong, C., Yen, J., Liu, P., Erbacher, R.F.: Learning from experts’ experience: toward automated cyber security data triage. *IEEE Systems Journal* (2018)
67. Zimmerman, C.: Ten strategies of a world-class cybersecurity operations center. *MITRE Technical Report* (2014)

A Additional Details

A.1 Annex of the Systematic Literature Review

The preliminary check to get an initial understanding of the state of the art was done qualitatively by two authors in Dec. 2024. At the time, we could not find any work that focused on our RQs, which led to us carrying out our study.

The paper collection phase of our SLR was done (in Dec. 2025, prior to our submission to DIMVA’26) procedurally by entering the queries and retrieving the results provided by Google Scholar. For defining the search terms, they stem from the phrasing of RQ0. Specifically: “*SOC/alert/explainability*”-related keywords are straightforward given our focus; whereas those related to “user study” have been inspired by the SLR described in [41], which focused on analysing papers accepted to HICSS as either “technical” or “user study” (or both), and specifically used the term “survey” as a subgroup of user studies. To exclude non-peer-reviewed works, we checked if, for any given result, there was a corresponding entry in a peer-reviewed venue. These procedures do not involve any form of qualitative assessment, but were repeated twice (both in Dec. 2025).

For analysing the papers included in our SLR, we adopted a dual-reviewer system (similarly to [48,41]): two authors reviewed each work and then discussed their findings to reach a consensus. The focus was on ascertaining (a) if the paper carried out an *user study* and, if so: (b) *who participated* in the user study—both in terms of sample size and participant’s background, e.g., SOC practitioners, or other experts; as well as (c) the *type* of user study—e.g., a survey, an interview, or a field experiment (like the one we did in our paper); and, finally, (d) if the paper had strong ties with SOC-related contexts. The analyses of two authors were compared and meetings were held to reach a consensus in cases of discrepancies (we also had one meeting to validate our final results in February 2026). Such an approach increases the reliability of our findings [21].

A.2 Annex to the Ethical Considerations

Our institutions do not mandate an explicit Ethic Review Board (ERB) approval to carry out the research discussed in this work; moreover, at the time of carrying out our study, no formal ERB process existed at our institutions. Nevertheless, we followed established ethical guidelines in our study [8].

First, participants were made aware of the nature of our study, and that their responses would be used for research purposes. Such “debriefing and request for consent” was carried out in two phases: upon sending the invitation to participate in the field experiment; and at the beginning of the field experiment.

Second, our study complied with the ethical standards of the partnered SOC/company. Importantly, it was ensured that participating in the study would have no negative impact on the participants. In addition, no psychological pressure was exerted on the participants, and the fact that the field study was not of a professionally-evaluative nature had been clearly communicated.

Third, all data was collected in an anonymous fashion—and the participants were made aware of this. Furthermore, to preserve our participants’ anonymity, we only release aggregated data or (short excerpts of) “translated” data, meaning that it is virtually impossible to link any of the information reported in this paper (or any of its derivative) to the specific individual. Even when sharing data among the researchers involved in this paper, we ensured that such data was exchanged using systems/software linked to our institutions.

A.3 Sample Description (aggregated, for anonymity/confidentiality)

We report additional information obtained via our preliminary questionnaire.

Demographics. 12 SOC employees participated in our study. Six have an MSc. degree, one a BSc., and five have completed an apprenticeship. One has a school-leaving certificate, while another dropped out of university. 11 participants completed their training in the IT sector, and one was specifically trained in IT security. In terms of professional experience, >70% have 10+ years of experience in the IT sector. One person has <1 year of experience, while the remaining participants have 3–10 years of professional experience. As SOC analysts, 4 have been working for <6 months, while the rest have been in this role

for 6–36 months. All participants had previously worked in other areas of IT. Network engineering (65%), system administration (57%), software development (50%), and IT helpdesk (42%) were mentioned particularly frequently.

Self-perception of competences Seven people stated that they have basic knowledge. Four people categorised themselves as advanced in a specific area. One person rated themselves as advanced in several areas.

Technological background In terms of the tools used, 85% stated that they work regularly with a SIEM tool. 65% already had experience with packet capture technologies and 50% with firewalls. 28% of the participants had already worked with threat intelligence, while intrusion detection systems (IDS) and detection & response (EDR) were mentioned less frequently (resp. 14%, 20%).

Log analysis experience. 92% stated that they had experience in analysing logs. Windows logs were mentioned most frequently (65%), followed by firewall logs (50%), web server and proxy logs (43% each), and EDR (8%) logs.

Assessment of alarms. Participants were asked to rate their confidence in (a) interpreting and (b) recognising security alarms on a 1–5 scale. For the former, the average score was 2.64; for the latter, the mean value was 2.71.

Dealing with uncertainties 92% stated that they consulted colleagues in case of uncertainties; however 71% participants also relied on their own research, analysing additional logs and comparing with existing playbooks. Only 33% stated that they would create a ticket and pass the case on if they were unsure.

Attitude towards use of AI. Regarding AI support, two participants stated that they do not use AI and feel safe doing so. The remaining ten people were divided into two groups: Half use AI but feel unsafe doing so. The other half do not currently use AI, but are also unsure whether it would be useful.

Remark. Some of our participants had little expertise with some tools. However, this simply denotes that such participants do not use such tools in their daily routines. This does not change the fact that such people are professional SOC employees, and that such tools are always available to be consulted for SOC-related duties. Hence, the ecological validity of our study is preserved.

A.4 Exemplary codes

We provide some examples of our reasoning for *Cases 1* and *2*. For *Case 1*, all coders agreed that a correct explanation had to mention “nessus scan” or equivalent; an exemplary incorrect explanation stated “client access to the internet”, deemed vague by all coders. For *Case 2*, only P12 provided a valid explanation with “developer test”: despite being short, it showed that P12 understood that it was an FP because it was due to some explicitly allowed internal tests triggering alarms; in contrast, a wrong explanation by P6 was “download Ubuntu”: while not strictly incorrect, such software-download operations *should be treated as TPs in this SOC as they can conceal malicious activities and demand further scrutiny*. (*Case 2* is an FP is because there was an explicit “developer rule” that was triggered, so the case should have been closed as an FP (and only P12 made it clear). Intriguingly, R3 considered P12’s answer as ✗ (because it was vague to R3), but R1 deemed it phrased in a contextually-correct way.